Đánh giá định lượng bộ phát hiện chuỗi cung ứng npm

NT230 – Đề tài D04: Supply Chain Compromise

Nhóm 02

Tóm tắt

Báo cáo trình bày phương pháp và kết quả đo hiệu năng của bộ phát hiện đa lớp `detector.py` trên hai tập dữ liệu: tập tổng hợp do `data_gen.py` sinh ra và tập gồm 1 000 gói npm thật (500 gói độc hại, 500 gói phổ biến). Trên tập tổng hợp, detector đạt Precision, Recall và F1 đều bằng 100%. Trên dữ liệu thật, các chỉ số giảm còn Precision 78,9%, Recall 66,6%, F1 72,2% và FPR 17,8%. Phân tích theo từng lớp cho thấy Layer 1 (siêu dữ liệu) một mình cho F1 cao hơn toàn hệ thống, Layer 2 gây phần lớn báo động nhầm và Layer 3 không đóng góp phát hiện nào.

1 Mục tiêu và chỉ số

Mục tiêu là đo khả năng phân biệt gói độc hại với gói sạch của detector và phân tích sự đánh đổi giữa tỷ lệ phát hiện và tỷ lệ báo động nhầm. Mỗi gói được gán nhãn *MALICIOUS* khi tổng điểm rủi ro đạt ngưỡng (mặc định 35). Với TP, FP, TN, FN là số gói tương ứng trong ma trận nhầm lẫn:

$$\text{Precision} = \frac{TP}{TP + FP}, \qquad \text{Recall} = \frac{TP}{TP + FN},$$

$$F_1 = \frac{2 \cdot \text{Precision} \cdot \text{Recall}}{\text{Precision} + \text{Recall}}, \qquad \text{FPR} = \frac{FP}{FP + TN}.$$

2 Dữ liệu thử nghiệm

2.1 Tập tổng hợp

Sinh bằng `data_gen.py` (seed 42), gồm 1 000 gói: 555 sạch, 155 chèn hook vòng đời, 151 Dependency Confusion và 139 làm rối mã Base64. Nhãn lấy từ `ground_truth.json`. Mẫu độc do cùng nhóm viết nên có lệch (bias) so với luật của detector.

2.2 Tập dữ liệu thật

Gồm 1 000 gói, tỷ lệ 50/50:

- **500 gói độc hại**: lấy ngẫu nhiên (seed cố định) từ kho *DataDog malicious-software-packages-dataset*, mục npm. Gồm 467 gói `malicious_intent` và 33 gói `compromised_lib` (thư viện hợp lệ bị chèn mã độc).
- **500 gói sạch**: các gói npm được xếp hạng phổ biến nhất theo công cụ tìm kiếm của npm registry, tải trực tiếp bằng tệp `.tgz` (không chạy `npm install`, không thực thi script cài đặt).

Mẫu độc chỉ được giải nén và đọc tĩnh trong máy ảo Ubuntu cô lập. Nhãn "sạch" là giả định, chưa được quét lại bằng công cụ khác.

3 Phương pháp

Chạy `evaluate.py` với ngưỡng 35. Công cụ chạy detector hai lượt (bật và tắt whitelist). Hai gói có `package.json` lỗi được ghi là *ERROR* và bị tính là sạch. Sau đó dùng điểm rủi ro và điểm từng lớp trong nhật ký viễn trắc để quét ngưỡng và phân tích đóng góp từng lớp mà không cần quét lại. Quét toàn bộ tập thật mất khoảng 15 phút 48 giây trên máy ảo một nhân.

4 Kết quả

4.1 Tập tổng hợp và tập thật

	Precision	Recall	F1	FPR
Tổng hợp (whitelist bật)	100,00%	100,00%	100,00%	0,00%
Tổng hợp (whitelist tắt)	76,59%	100,00%	86,74%	24,50%
Dữ liệu thật	78,91%	66,60%	72,23%	17,80%

Bảng 1: Hiệu năng detector, ngưỡng 35.

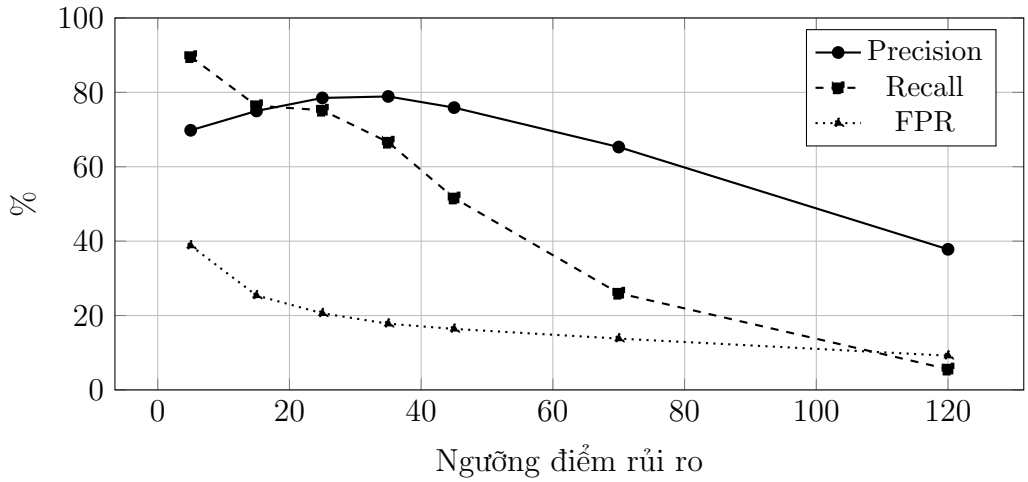
Ma trận nhầm lẫn trên dữ liệu thật: TP = 333, FP = 89, TN = 411, FN = 167. Tỷ lệ phát hiện theo loại: `malicious_intent` 64,9%, `compromised_lib` 90,9%; tỷ lệ gói sạch được cho qua là 82,2%.

Whitelist giảm FPR từ 24,5% xuống 0% trên tập tổng hợp, nhưng trên dữ liệu thật hai chế độ cho kết quả giống hệt nhau (cùng FP = 89): các gói sạch thật trong tập này hầu như không dùng hook biên dịch nằm trong whitelist.

4.2 Ảnh hưởng của ngưỡng

Ngưỡng	Precision	Recall	F1	FPR
5	69,8%	89,6%	78,5%	38,8%
15	75,0%	76,4%	75,7%	25,4%
25	78,5%	75,2%	76,8%	20,6%
35	78,9%	66,6%	72,2%	17,8%
45	75,9%	51,6%	61,4%	16,4%
70	65,3%	26,0%	37,2%	13,8%
120	37,8%	5,6%	9,8%	9,2%

Bảng 2: Quét ngưỡng điểm rủi ro trên dữ liệu thật.



Hình 1: Precision, Recall và FPR theo ngưỡng.

Hạ ngưỡng làm tăng Recall nhưng kéo theo FPR tăng; nâng ngưỡng thì ngược lại. F1 cao nhất trong các ngưỡng đã quét là 76,8% tại ngưỡng 25. Ngưỡng này được chọn bằng cách quan sát chính tập đánh giá nên không nên xem là tối ưu tổng quát.

4.3 Đóng góp từng lớp

Cấu hình	Precision	Recall	F1	FPR	TP/FP
Chỉ Layer 1	97,5%	61,2%	75,2%	1,6%	306/8
Chỉ Layer 2	32,3%	8,0%	12,8%	16,8%	40/84
Chỉ Layer 3	0,0%	0,0%	0,0%	0,0%	0/0
Layer 1+2	79,1%	66,6%	72,3%	17,6%	333/88
Cả ba lớp	78,9%	66,6%	72,2%	17,8%	333/89

Bảng 3: Đóng góp từng lớp ở ngưỡng 35.

5 Phân tích

Layer 1 cho tín hiệu mạnh nhất. Hook `preinstall`/`postinstall` xuất hiện ở phần lớn gói độc bị phát hiện (183 và 125 gói), trong khi chỉ 8 gói sạch bị Layer 1 báo nhầm (7 gói có hook `postinstall` hợp lệ ngoài whitelist).

Layer 2 gây hầu hết báo động nhầm. Trong 89 FP, các luật chính là entropy cao (51 gói), chuỗi mã hóa dài (51 gói) và lời gọi `eval`/`child_process` (36 gói). Đây là đặc trưng phổ biến của thư viện hợp lệ (mã nén, hằng số mã hóa, công cụ dòng lệnh), nên luật khớp mẫu thiếu khả năng phân biệt ngữ cảnh. So với Layer 1 riêng lẻ, thêm Layer 2 tăng thêm 27 TP nhưng thêm 81 FP.

Layer 3 chưa tạo ra phát hiện. Trong cài đặt hiện tại, Layer 3 chỉ dò biểu thức chính quy trong chuỗi `scripts` (mô phỏng), không chạy `npm install` trong hộp cát, nên không có TP nào.

Bỏ sót. Trong 167 FN, 52 gói có điểm 0 và 115 gói có điểm dưới ngưỡng, chủ yếu chỉ dính luật mô tả trống (+5). Các gói này không có hook cài đặt, phiên bản bất thường hay mẫu mã nào mà detector tìm kiếm. Báo cáo này chưa phân tích mã nguồn các gói đó nên không kết luận về hành vi thật của chúng.

Về kết quả 100% trên tập tổng hợp. Mẫu độc và luật phát hiện do cùng nhóm thiết kế, nên 100% phản ánh sự khớp giữa hai phần hơn là sức mạnh tổng quát. Kết quả trên dữ liệu thật là thước đo đáng tin hơn.

6 Hạn chế

- Tỷ lệ 50/50 là nhân tạo; ngoài thực tế gói sạch nhiều hơn rất nhiều, nên Precision thực tế sẽ thấp hơn.
- Nhãn sạch là giả định; hai gói lỗi JSON bị tính là sạch.
- Mẫu độc chủ yếu là kiểu `malicious_intent`; chỉ 33 mẫu `compromised_lib`, quá ít để kết luận riêng.
- Tập thật chưa dùng gói bị làm rối mã có chủ đích để đo Recall theo mức độ làm rối.
- Ngưỡng ở mục 4.2 được chọn trên cùng tập đánh giá.

7 Kết luận

Detector đạt kết quả tuyệt đối trên mẫu tự sinh nhưng chỉ đạt F1 72,2% và FPR 17,8% trên dữ liệu thật. Layer 1 là thành phần hiệu quả nhất; các luật entropy, chuỗi mã hóa

và `child_process` ở Layer 2 gây nhiều báo động nhầm; Layer 3 cần được cài đặt thành phân tích động thật để có đóng góp. Hướng cải thiện: giảm trọng số hoặc bổ sung ngữ cảnh cho luật Layer 2, mở rộng whitelist theo dữ liệu thật, và bổ sung tín hiệu hành vi thật.